

Phishing Email Detection & Awareness Report

A Comprehensive Enterprise Vulnerability Assessment and Human-Centric Defense Framework

<i>Prepared By:</i>	Levy Gaël Ndayisenga
<i>Organization</i>	Future Interns
<i>Assignment</i>	Task 2: Phishing Email Detection and Awareness System
<i>Date:</i>	May 18, 2026

Executive Summary

In modern enterprise and government infrastructures, technical perimeter defenses such as firewalls and endpoint detection networks are continuously challenged by deceptive communication vectors. Malicious actors frequently exploit the human element through electronic mail manipulation to bypass deep hardware restrictions. This project report details a structured investigation into inbound email authentication, risk classification, and institutional security awareness protocols.

Utilizing advanced tracking methodologies including message transit header analysis via the Google Admin Toolbox MessageHeader utility, this system classifies incoming correspondence into distinct risk paradigms: Safe, Suspicious, and Phishing. By mapping cryptographic compliance metrics against structural text cues, this framework provides automated administrative guidance and operational user directives to transform personnel from vulnerability targets into proactive institutional firewalls.

1. Technical Methodology & Analysis Framework

To determine the legitimacy of inbound communication, a security analyst cannot rely on the visual surface interfaces provided by modern email clients. Attackers routinely disguise client-facing data. The definitive investigative source is the *Internet Message Header*, a hidden cryptographic metadata record appended to every electronic document during transport.

The primary evaluation criteria used within this detection engine focus on three architectural authentication standards:

1. **SPF (Sender Policy Framework):** A public DNS record that lists all authorized IP addresses permitted to distribute email on behalf of a specific domain name.
2. **DKIM (DomainKeys Identified Mail):** An asymmetric cryptographic signature embedded within the header that validates the email text was genuinely sent by the domain owner and was not altered mid-transit.
3. **DMARC (Domain-based Message Authentication, Reporting, and Conformance):** A governance policy framework that directs receiving servers on how to handle messages that fail SPF or DKIM checks (e.g., monitor, quarantine, or completely reject).

The Administrative Review Workflow

When a warning indicator is flagged, the raw text-string transit data is copied via the server client's original source console and pasted directly into the parsing engine interface. The algorithm extracts the linear sequence of '*Received: from*' tags, tracking the physical path from origin nodes to intermediate perimeter gateways. If a validation anomaly is exposed, such as a cryptographic *FAIL outcome* or *infrastructure look-alike mismatches*, the message is routed immediately to protective quarantine structures.

2. Threat Classification & Comparative Analysis

2.1. Safe Email Analysis



Threat Classification: SAFE / Risk Score: Low / Minimal

Analyst Evaluation: This document exhibits absolute structural integrity. The display text fields align completely with the sending domain. Evaluation through the parsing framework shows a comprehensive cryptographic validation match. The routing hops indicate direct delivery from legitimate provider infrastructure directly into inbound service pathways without unauthorized intermediate relays.

MessageId	44073421.14656128.1779048529131@lva1-app57288.prod.linkedin.com
Created at:	5/17/2026, 10:08:49 PM GMT+2 (Delivered after 2 sec)
From:	Project Management via LinkedIn <newsletters-noreply@linkedin.com>
To:	Levy Gael Ndayisenga <levygaeln@gmail.com>
Subject:	Why Coursera Plus May Be One of the Best Investments You Make in Your Career This Year
DKIM:	pass with domain maile.linkedin.com Learn more

#	Delay	From *	To *	Protocol	Time received
0	1 sec	maile-ga.linkedin.com	→ [Google] mx.google.com	ESMTPS	5/17/2026, 10:08:50 PM GMT+2
1			→ [Google] 2002:a17:902:aa8a:b0:2b2:aa7b:b3bd	SMTP	5/17/2026, 10:08:50 PM GMT+2
2	1 sec		→ [Google] 2002:a17:504:8a0f:b0:1e48:1819:47f	SMTP	5/17/2026, 10:08:51 PM GMT+2

2.2. Phishing Email Simulation

From: IT Service Desk <support@office365-security-update.com>
To: internal-employee@target-org.com
Date: May 18, 2026, 09:14 AM CAT
Subject: CRITICAL: Immediate Password Reset Required - Security Breach Detected

⚠ CAUTION: This message originated from outside the organization network.

Dear Employee,

Our corporate security gateway detected an unauthorized login attempt to your workstation originating from an unverified external IP address. To safeguard network infrastructure and protect data records, your system password must be updated immediately. Failure to verify your identity within 24 hours will result in the temporary suspension of access.

[Verify Account & Reset Password Now]

Threat Classification: PHISHING | Risk Score: Critical / High

Analyst Evaluation: This communication is an active credential-harvesting exploit. The sender domain exhibits Typosquatting, using a malicious look-alike name (office365-security-update.com) to mimic official Microsoft infrastructure. Extracting this header yields an explicit SPF/DKIM FAIL because the delivery domain is completely unverified. The embedded hyperlink resolves to an external credential collection page.

2.3. Suspicious Email Simulation

From: Accounts Payable / Billing Dept <invoice.desk392@gmail.com>
To: finance-clearance@target-org.com
Date: May 15, 2026, 11:02 AM CAT
Subject: Overdue Payment Request: Invoice #INV-2026-8841

Hello Team,

Please find attached our outstanding itemized statement for corporate consultancy services delivered last month. Kindly process the remittance at your earliest convenience to avoid service disruptions.

📎 Attachment Blocked: Invoice_INV_2026_8841.pdf.exe

Threat Classification: SUSPICIOUS | Risk Score: Moderate / Medium

Analyst Evaluation: This document represents a multi-tiered exploit delivery attempt. While the header technically passes basic Gmail alignment, the business context creates immediate red flags. A professional billing node will not distribute invoices from an anonymous public domain (@gmail.com). Furthermore, the payload file uses a hidden double extension (.pdf.exe) designed to execute background script malicious files.

3. Institutional Security Governance and Awareness Matrix

Because sophisticated adversaries routinely adapt their code structures to bypass technical filters, human observation remains the final defensive tier for enterprise security infrastructure. The following operational directives outline mandatory protocols for institutional personnel.

3.1. Operational User Guidelines:

Mandatory Verification of Display Nodes: Personnel must click on the sender's friendly display text to reveal the hidden string domain underneath.

Avoid Artificial Deadlines: Adversaries rely on fear and immediate deadlines to bypass rational thought. Treat unexpected emails demanding action within 24 hours as hostile.

Hyperlink Inspection Protocols: Hover over target hyperlinks to show the structural URL destination before interacting with any embedded text elements.

3.2. Incident Remediation Framework

Isolation: Disconnect affected workstations from the local area network instantly to halt any malicious lateral movement.

Credential Revocation: Invalidate running session tokens and force an immediate out-of-band master password reset.

Perimeter Hardening: Extract structural IP indicators and apply absolute blocks on firewall policies.

4. Conclusion

Building a resilient enterprise defense network requires a combination of automated technical scanning tools and continuous security awareness training. By combining analytical processes like header evaluation with basic defensive rules for employees, organizations can greatly reduce their susceptibility to social engineering attacks. This report demonstrates that an informed, alert workforce is an essential component of any modern cybersecurity strategy.